

Abdul Wahid

EC-Council CND (Certified Network Defender)

Network Segmentation & Web Application Attack Simulation

Executive Summary

This report documents the setup and execution of a controlled Network Security lab using VMware Workstation. The lab demonstrates fundamental network segmentation techniques using pfSense as a firewall/router, and illustrates how a poorly secured web application can be exploited through multiple attack vectors.

The lab environment consists of three virtual machines — a pfSense firewall, a Kali Linux attacker machine, and a Windows Server 2019 victim hosting a vulnerable ASP.NET web application. The attacker machine is placed on the WAN side (VMnet8 / NAT, subnet 192.168.80.0/24), while the victim machine sits on the LAN side (VMnet3 / Host-Only, subnet 192.168.30.0/24), separated by the pfSense firewall.

Four attack phases were carried out:

- **Phase 1 – Reconnaissance using Nmap to identify open ports and services**
- **Phase 2 – SQL Injection via Burp Suite to bypass authentication**
- **Phase 3 – Stored Cross-Site Scripting (XSS) to inject malicious JavaScript**
- **Phase 4 – Brute-force credential attack using Hydra**

The lab confirms that weak input validation combined with absent account-lockout policies can result in full system compromise. All testing was performed in a fully isolated virtual environment with no connection to production systems.

Contents

Executive Summary 2
1. Introduction 4
2. Lab Environment Setup 4
2.1 Hypervisor & Host 4
2.2 Virtual Machines 4
3. Network Design 5
3.1 VMnet Adapter Configuration 5
3.2 IP Address Summary 6
4. pfSense Installation and Configuration 6
4.1 LAN Interface Configuration Steps 7
4.2 Confirmation 9
5. Attacker Machine Configuration (Kali Linux) 10
5.1 Network Adapter Setup 10
5.2 Default Route Configuration 11
5.3 Connectivity Test 11
6. Victim Machine Configuration (Windows Server 2019) 12
6.1 Network Adapter Setup 12
6.2 IP Address Verification 12
6.3 Web Application 13
7. Multi-Stage Web Application Attack Simulation 13
7.1 Lab Scenario 13
Phase 1 — Reconnaissance (Nmap Scan) 13
Phase 2 — SQL Injection Attack (Burp Suite) 14
Phase 3 — Cross-Site Scripting (Stored XSS) 20
Phase 4 — Brute Force Attack (Hydra) 21
8. Attack Chain Summary 23
Full Compromise Path 23
9. Conclusion 24

1. Introduction

This lab demonstrates the configuration of a firewall using pfSense and the execution of controlled web application attacks in a virtual lab environment. The purpose of this module is to understand:

- Network segmentation
- Firewall configuration using pfSense
- Vulnerability exploitation techniques
- Impact of poor web application security

The lab includes three virtual machines:

- **pfSense — Firewall & Router**
- **Attacker Machine — Kali Linux**
- **Victim Machine — Windows Server 2019 (Web Server)**

All testing was performed in an isolated virtual environment.

2. Lab Environment Setup

2.1 Hypervisor & Host

Property	Value
Hypervisor	VMware Workstation
Host Operating System	Windows

2.2 Virtual Machines

VM Name	Operating System	Role
pfSense	pfSense 2.7.2-RELEASE	Firewall / Router
Attacker	Kali Linux (Rolling)	Attack Machine
Victim	Windows Server 2019	Web Server (IIS + ASP.NET)

3. Network Design

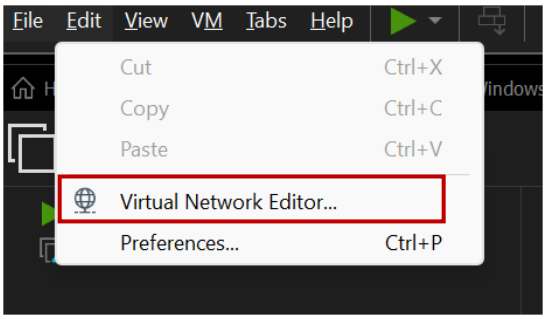
In VMware, a VMnet acts as a virtual switch to which virtual machines connect. Two VMnet adapters are used in this lab — one for the WAN interface and one for the LAN interface of pfSense.

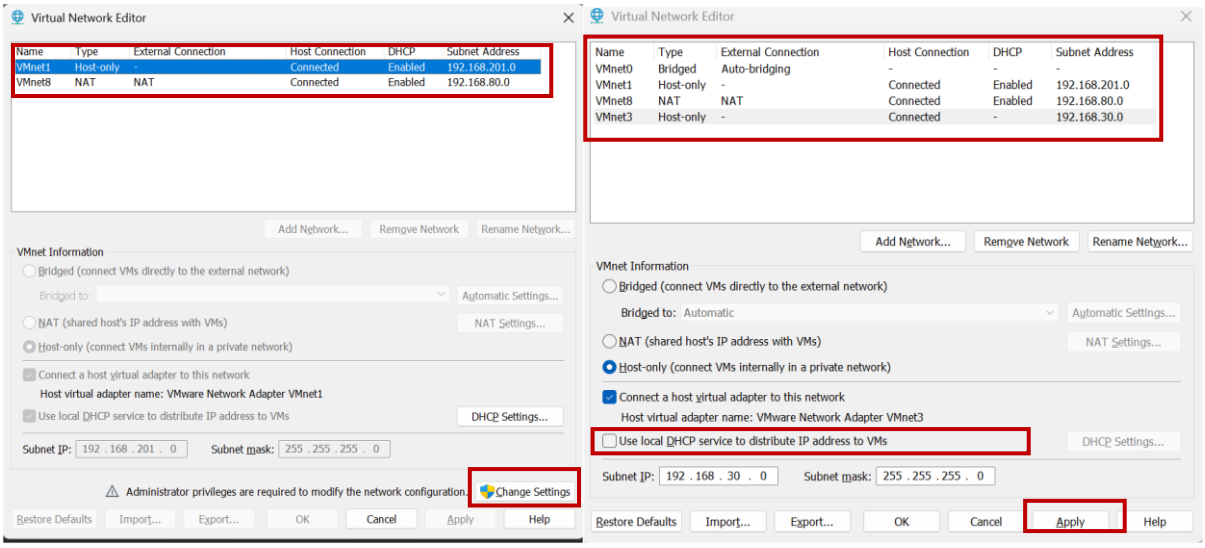
3.1 VMnet Adapter Configuration

VMnet	Type	Subnet	Purpose
VMnet8	NAT	192.168.80.0/24	WAN — pfSense WAN + Attacker (Kali)
VMnet3	Host-Only	192.168.30.0/24	LAN — pfSense LAN + Victim (Windows Server)

Configuration steps in VMware Virtual Network Editor:

- VMnet8 set to NAT with DHCP enabled — used for WAN interface
- VMnet3 set to Host-Only with DHCP disabled — used for LAN interface
- Both adapters applied and saved before starting any VM

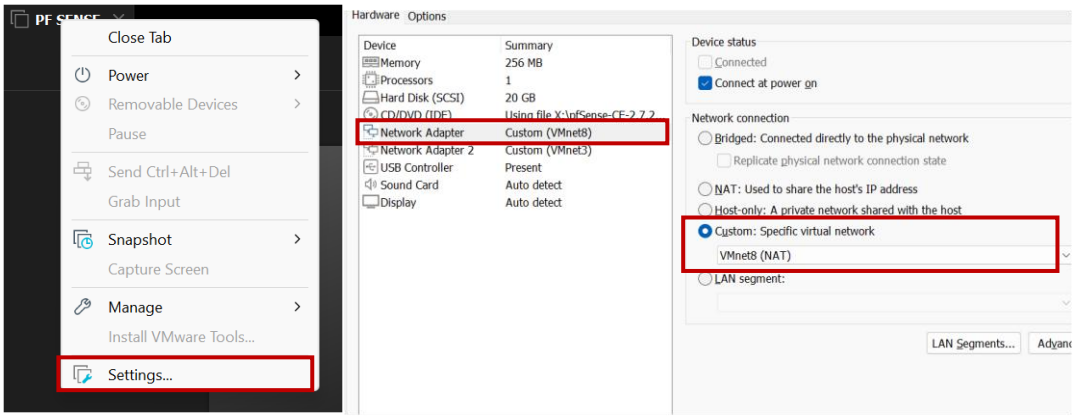


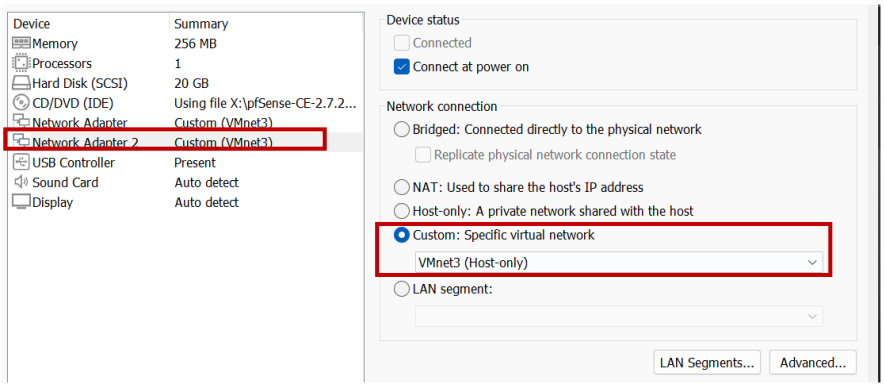


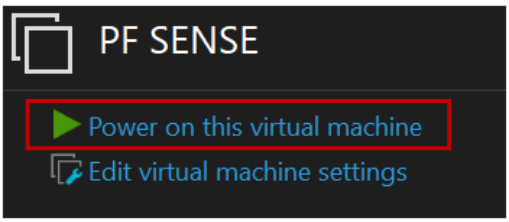
3.2 IP Address Summary

Device	IP Address	Interface / Notes
pfSense WAN (em0)	192.168.80.132/24	DHCP from VMnet8 (NAT)
pfSense LAN (em1)	192.168.30.99/24	Static — configured manually
Attacker (Kali)	192.168.80.129/24	DHCP from VMnet8 — same subnet as WAN
Victim (Windows)	192.168.30.113/24	DHCP from pfSense LAN pool

4. pfSense Installation and Configuration

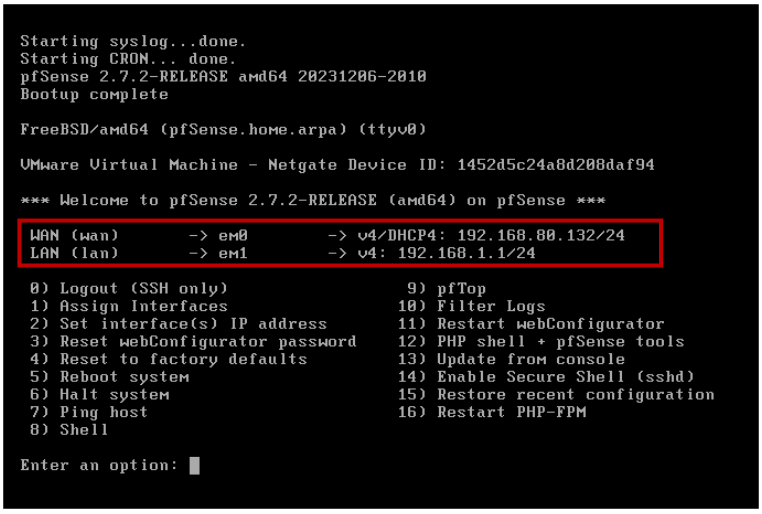






After starting the pfSense VM, the console confirms both interfaces are detected:

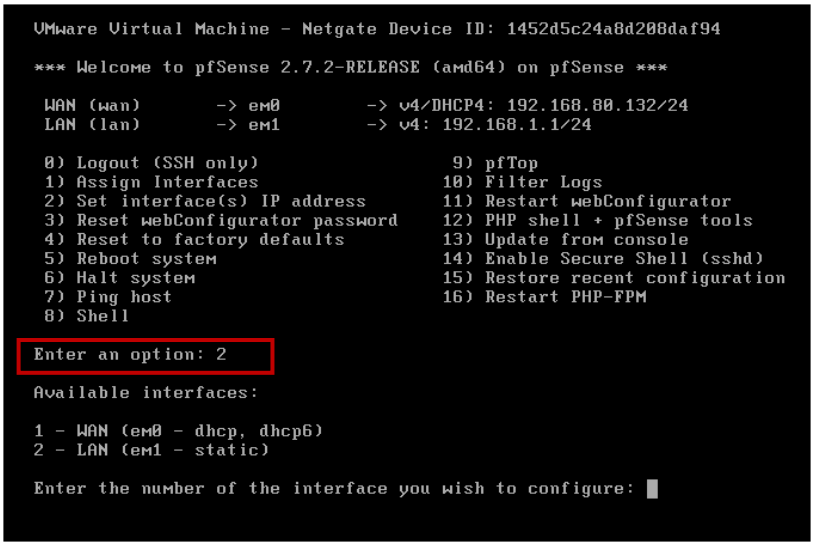
- em0 → WAN (connected to VMnet8)
- em1 → LAN (connected to VMnet3)



The WAN interface automatically receives an IP address via DHCP from VMware's NAT service. The LAN interface requires manual static IP configuration as shown below.

4.1 LAN Interface Configuration Steps

Step 1 — Enter option 2 (Set interface IP address)



Step 2 — Select interface 2 (LAN)

```
Available interfaces:

1 - WAN (em0 - dhcp, dhcp6)
2 - LAN (em1 - static)

Enter the number of the interface you wish to configure: 2
```

Step 3 — Decline DHCP for LAN

```
Available interfaces:

1 - WAN (em0 - dhcp, dhcp6)
2 - LAN (em1 - static)

Enter the number of the interface you wish to configure: 2

Configure IPv4 address LAN interface via DHCP? (y/n) n
```

Step 4 — Assign static IP matching Host-Only subnet

The VMnet3 Host-Only adapter subnet is 192.168.30.0. A static IP within this range is assigned to pfSense LAN:

```
Enter the new LAN IPv4 address.  Press <ENTER> for none:
> 192.168.30.99
```

Step 5 — Set subnet mask

```
Subnet masks are entered as bit counts (as in CIDR notation) in pfSense.
e.g. 255.255.255.0 = 24
     255.255.0.0   = 16
     255.0.0.0     = 8

Enter the new LAN IPv4 subnet bit count (1 to 32):
> 24
```

E

Step 6 — Skip IPv4 upstream gateway (LAN has none)

```
For a WAN, enter the new LAN IPv4 upstream gateway address.
For a LAN, press <ENTER> for none:
>
```

Step 7 — Decline IPv6 DHCP & skip IPv6 address

```
Configure IPv6 address LAN interface via DHCP6? (y/n) n
```

```
Enter the new LAN IPv6 address.  Press <ENTER> for none:
>
```

Step 8 — Enable DHCP server on LAN with IP range

```
Do you want to enable the DHCP server on LAN? (y/n) y
Enter the start address of the IPv4 client address range: 192.168.30.112
Enter the end address of the IPv4 client address range: 192.168.30.144
Disabling IPv6 DHCPD...
```

Step 9 — Keep HTTPS as web configurator protocol

```
Do you want to revert to HTTP as the webConfigurator protocol? (y/n) n

Please wait while the changes are saved to LAN...
 Reloading filter...
 Reloading routing configuration...
 DHCPD...
```

After configuration completes, the pfSense web configurator is accessible at:

```
The IPv4 LAN address has been set to 192.168.30.99/24
You can now access the webConfigurator by opening the following URL in your web
browser:
                https://192.168.30.99/

Press <ENTER> to continue.
```

4.2 Confirmation

Final interface state after successful configuration:

Interface	Physical Port	Address
WAN	em0	v4/DHCP4: 192.168.80.132/24
LAN	em1	v4: 192.168.30.99/24

```
VMware Virtual Machine - Netgate Device ID: 1452d5c24a8d208daf94

*** Welcome to pfSense 2.7.2-RELEASE (amd64) on pfSense ***

 WAN (wan)       -> em0        -> v4/DHCP4: 192.168.80.132/24
 LAN (lan)       -> em1        -> v4: 192.168.30.99/24

 0) Logout (SSH only)                  9) pfTop
 1) Assign Interfaces                 10) Filter Logs
 2) Set interface(s) IP address       11) Restart webConfigurator
 3) Reset webConfigurator password    12) PHP shell + pfSense tools
 4) Reset to factory defaults         13) Update from console
 5) Reboot system                     14) Enable Secure Shell (sshd)
 6) Halt system                       15) Restore recent configuration
 7) Ping host                         16) Restart PHP-FPM
 8) Shell

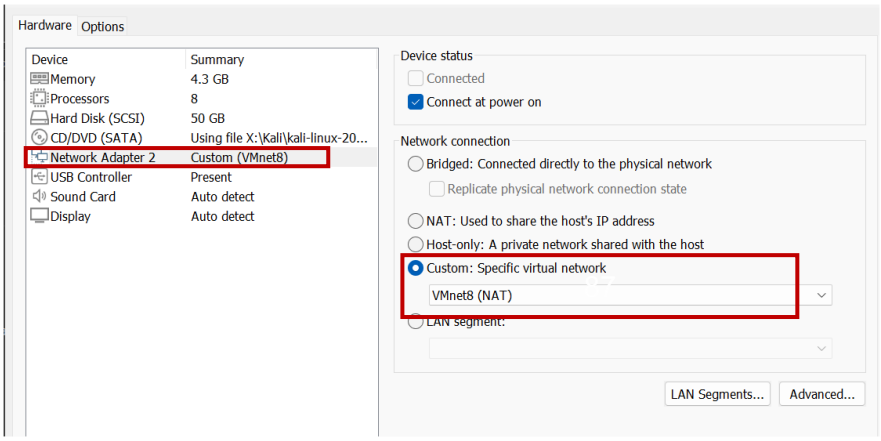
Enter an option:
```

5. Attacker Machine Configuration (Kali Linux)

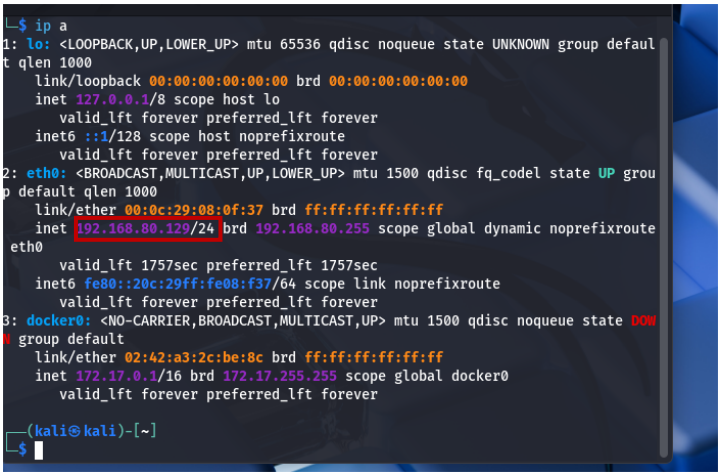
The Kali Linux attacker machine is connected to VMnet8 (NAT), placing it on the same subnet as the pfSense WAN interface. This simulates an external attacker attempting to reach the internal LAN through the firewall.

5.1 Network Adapter Setup

- Network adapter set to Custom → VMnet8 (NAT)



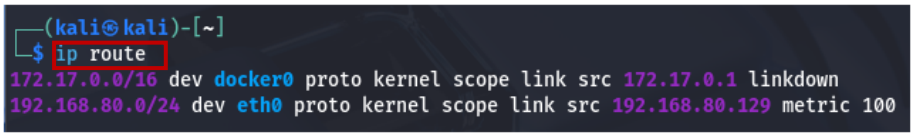
- IP obtained automatically via DHCP: 192.168.80.129/24
- Verified using: ip a



5.2 Default Route Configuration

The default gateway is set to the pfSense WAN IP so that traffic destined for the LAN is routed through the firewall:

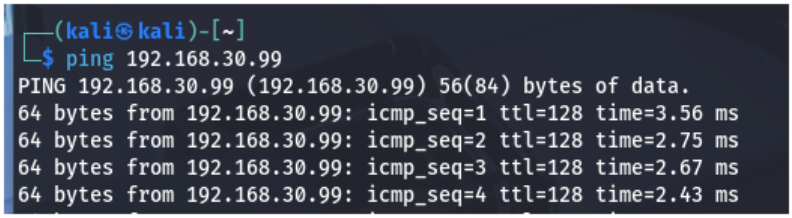
Verify the route:

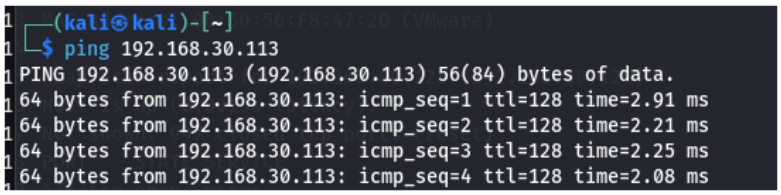


Note: These routing changes are temporary and will not persist after a reboot.

5.3 Connectivity Test

Ping to pfSense WAN confirms the attacker can reach the firewall:



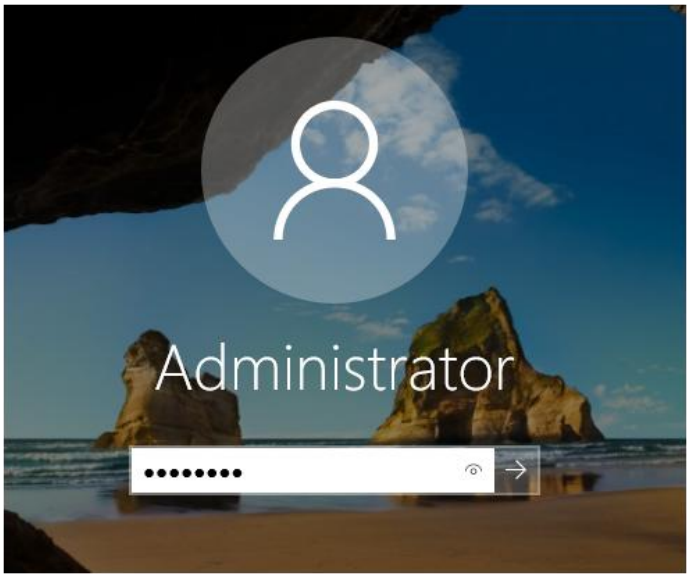


6. Victim Machine Configuration (Windows Server 2019)

The victim machine is a Windows Server 2019 instance running Microsoft IIS with a vulnerable ASP.NET web application backed by SQL Server.

6.1 Network Adapter Setup

- Network adapter set to Custom → VMnet3 (Host-Only)
- This places the victim on the LAN side behind pfSense



6.2 IP Address Verification

After boot, login with Administrator / Admin123 and run ipconfig to confirm the DHCP-assigned address:

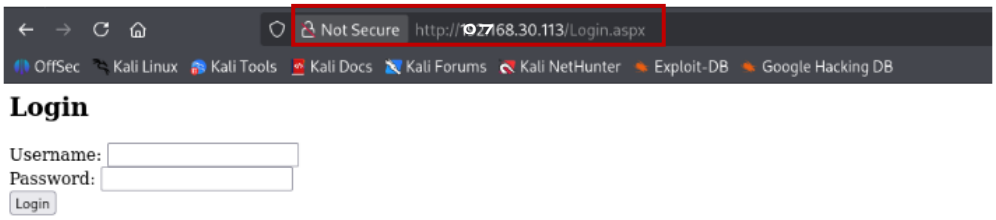
```
Ethernet adapter Ethernet0 2:

   Connection-specific DNS Suffix  . : home.arpa
   Link-local IPv6 Address . . . . . : fe80::b04f:2ee9:5d2b:9c5f%13
   IPv4 Address. . . . . . . . . . . : 192.168.30.113
   Subnet Mask . . . . . . . . . . . : 255.255.255.0
   Default Gateway . . . . . . . . . : 192.168.30.99
```

The victim received IP 192.168.30.113 from pfSense's DHCP pool (192.168.30.112–192.168.30.144), and its default gateway points to pfSense LAN (192.168.30.99). This confirms correct network placement.

6.3 Web Application

The web application hosted on IIS is accessible at:



7. Multi-Stage Web Application Attack Simulation

7.1 Lab Scenario

An internal web application hosted on the Windows IIS server (192.168.30.113) contains multiple vulnerabilities. The attacker, positioned on the WAN-side (192.168.80.129), performs a multi-phase attack:

- Network reconnaissance (Nmap)
- SQL Injection — authentication bypass
- Cross-Site Scripting (XSS) — stored script injection
- Brute-force authentication attack (Hydra)

Goal: demonstrate how poor security controls can lead to full system compromise.

Phase 1 — Reconnaissance (Nmap Scan)

Objective

Identify open ports and running services on the victim machine.

```
┌──(kali㉿kali)-[~/Desktop]
└─$ nmap -sS -T2 --mtu 8 192.168.80.128 -oN Combo-scan.txt

Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-07 15:15 -0500
Nmap scan report for 192.168.80.128 (192.168.80.128)
Host is up (0.00094s latency).
Not shown: 997 closed tcp ports (reset)
PORT    STATE SERVICE
135/tcp open  msrpc
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:D4:B4:9B (VMware)

Nmap done: 1 IP address (1 host up) scanned in 402.02 seconds
```

Flag Explanation

Flag	Meaning
-sS	SYN stealth scan — does not complete TCP handshake
-T2	Timing template — slower scan to reduce detection
--mtu 8	Fragment packets into 8-byte chunks to evade IDS/firewall
-oN	Save output in normal readable format

Results Observed

- Port 135/tcp open — msrpc
- Port 139/tcp open — netbios-ssn
- Port 445/tcp open — microsoft-ds
- OS detected: Windows (VMware MAC prefix confirmed)

Impact

Attacker identifies the target is a Windows machine with SMB services exposed. Pivot to web application testing on port 80 (HTTP) using the known IP.

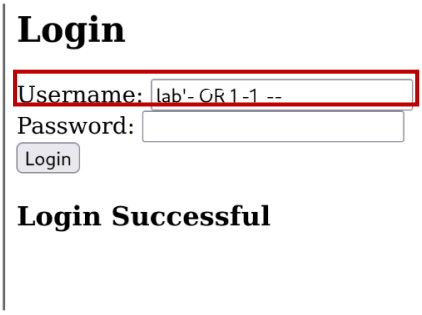
Phase 2 — SQL Injection Attack (Burp Suite)

Objective

Bypass authentication on the Login.aspx page using SQL Injection.

Step 1 — Direct SQL Injection Test

Open Firefox in Kali Linux and navigate to http://192.168.30.113/Login.aspx. Enter the following Boolean-based payload in the username field and leave the password blank:



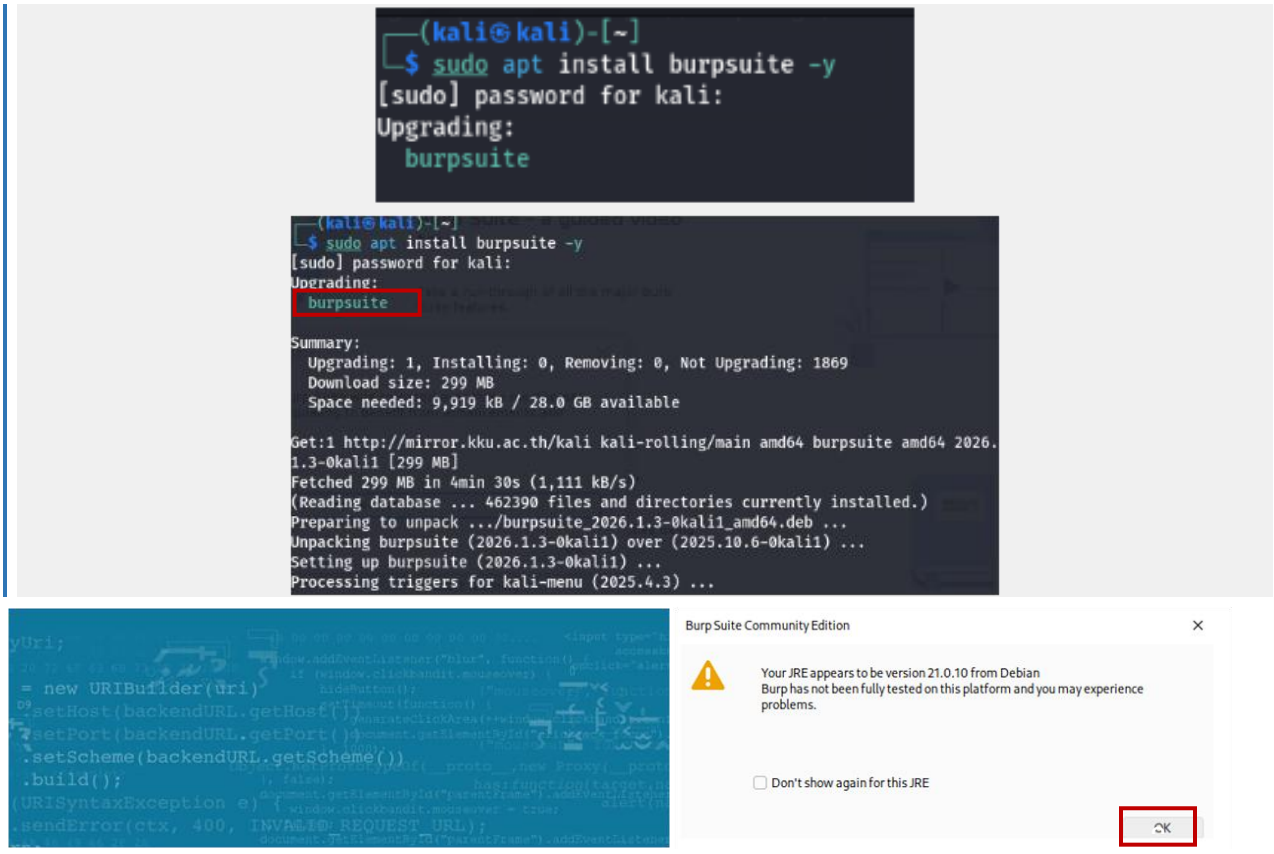
Result: Login Successful — confirms the application is vulnerable to SQL Injection.

What is Boolean-Based Blind SQL Injection?

Boolean-based SQL injection is a blind injection technique where the attacker infers database information by observing the application's response to SQL queries that evaluate to either true or false. The application does not return raw data or error messages — instead, the attacker reads the behavior (login success vs. failure) to determine truth.

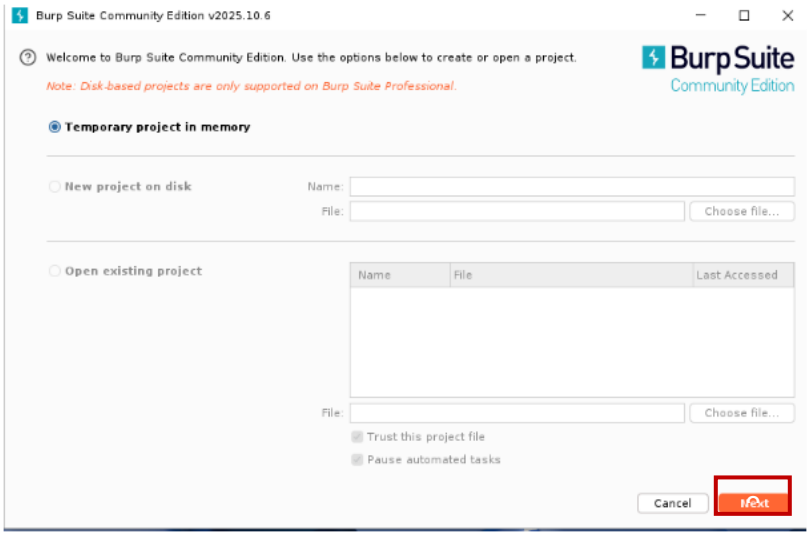
Step 2 — Burp Suite Intercept

Launch Burp Suite Community Edition in Kali Linux:

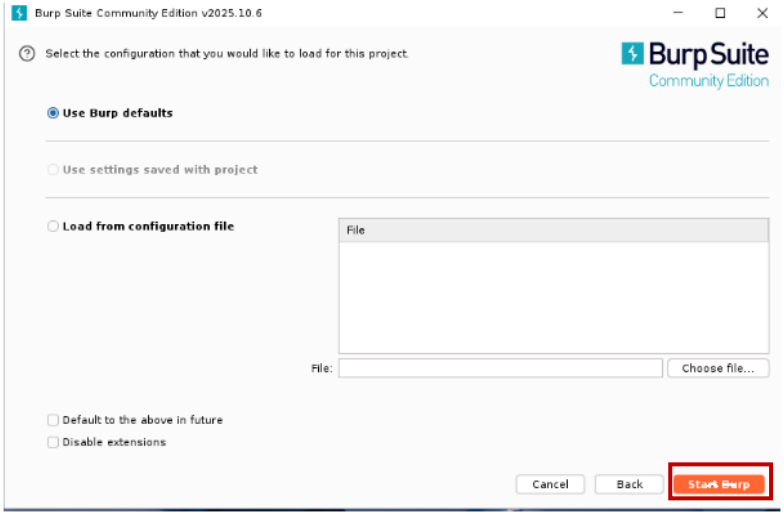


Burp Suite launch sequence:

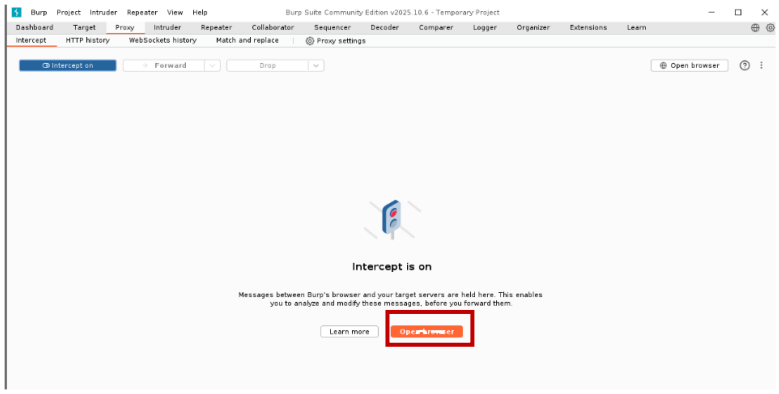
- Select Temporary project in memory → Next



- Select Use Burp defaults → Start Burp

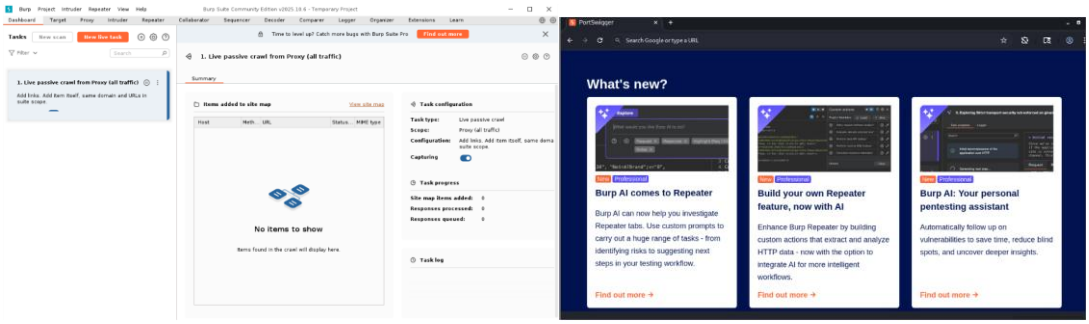


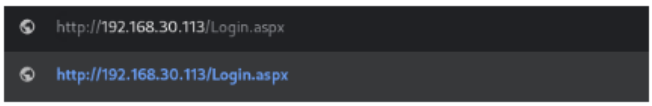
- Go to Proxy tab → Turn on Intercept → Open Browser



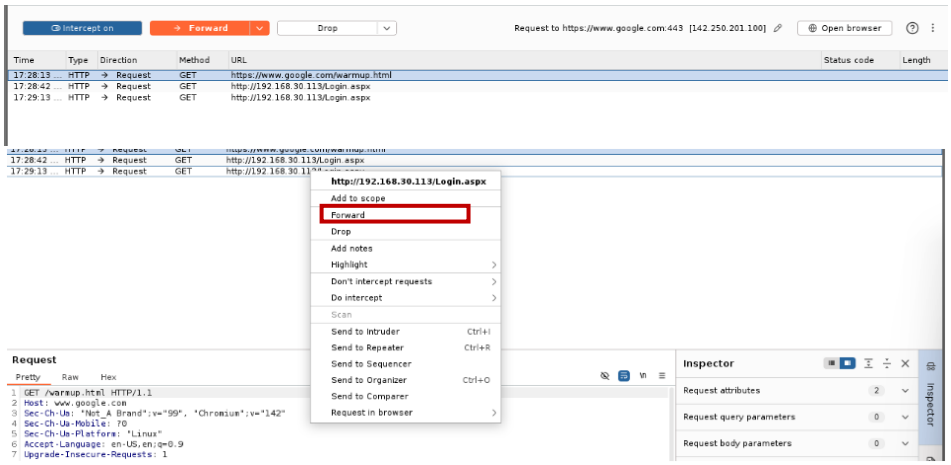


- In the Burp browser, navigate to http://192.168.30.113/Login.aspx

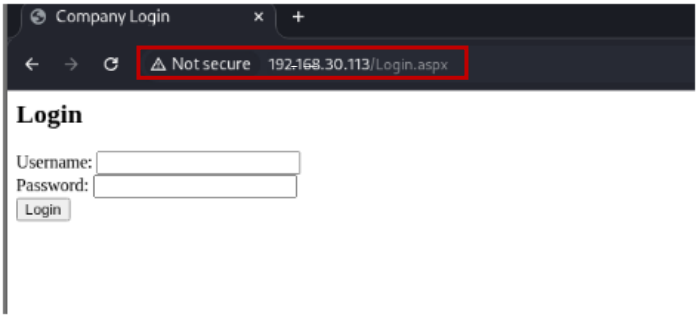




- In Burp HTTP History, right-click the GET request → Forward



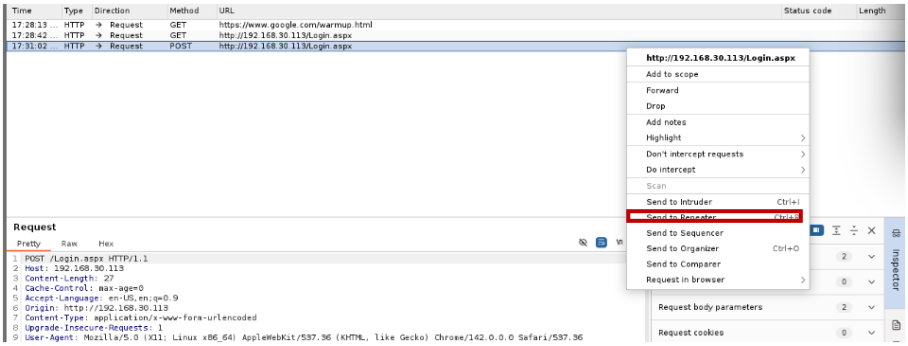
- Enter any credentials and click Login



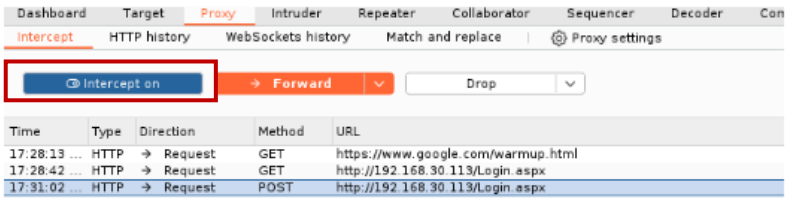
- Go back to Burp — the POST request will appear



- Right-click the POST request → Send to Repeater

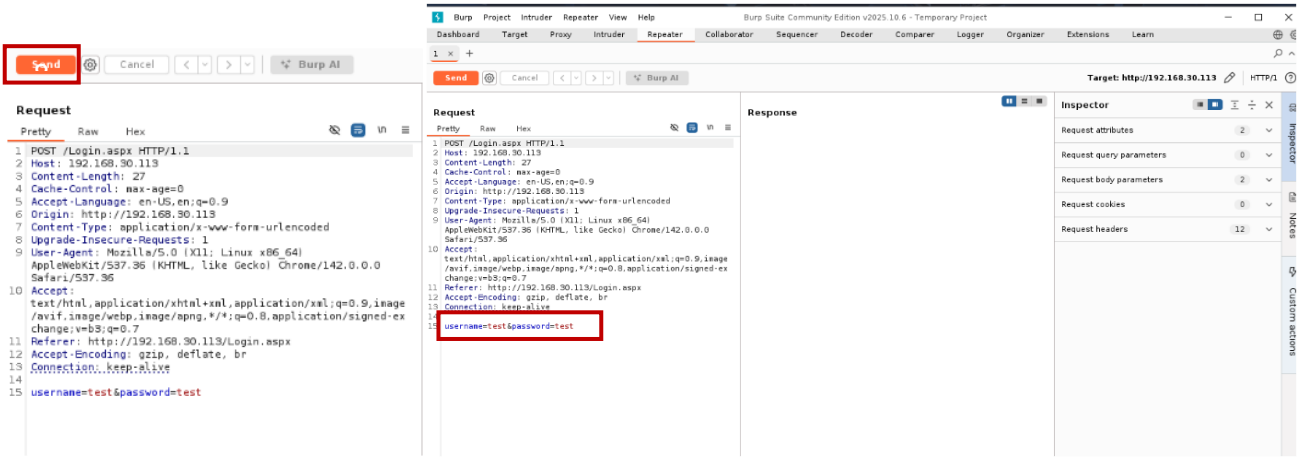


- Turn Intercept OFF immediately (to prevent VM instability)



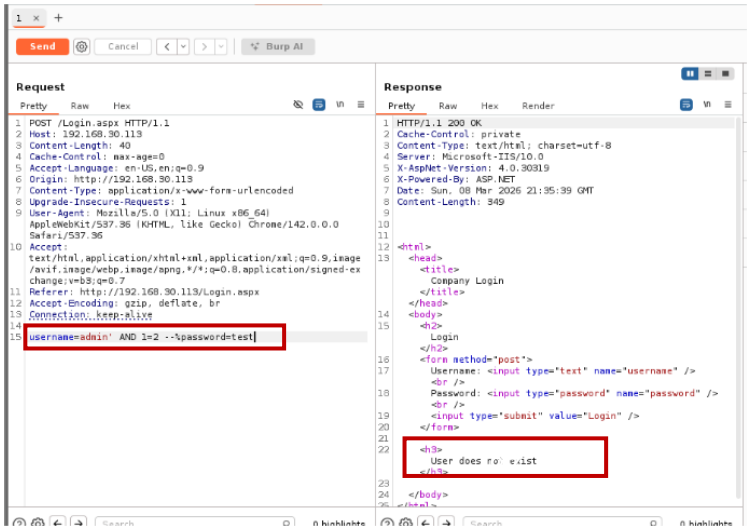
Step 3 — Boolean Injection via Repeater

In the Repeater tab, modify line 15 of the request body:



Click Send. Response confirms Login Successful (HTTP 200, body contains 'Login Successful').

Now test with false condition:



Result: Response returns 'User does not exist' — Boolean-based injection confirmed.

Findings Summary

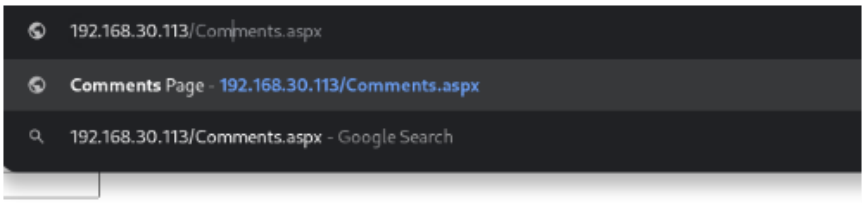
Finding	Detail
Backend Database	SQL Server (ASP.NET + Microsoft-IIS/10.0 confirmed)
Injection Type	Boolean-based Blind SQL Injection
Vulnerable Parameter	username field in POST /Login.aspx
Impact	Full authentication bypass without valid credentials

Phase 3 — Cross-Site Scripting (Stored XSS)

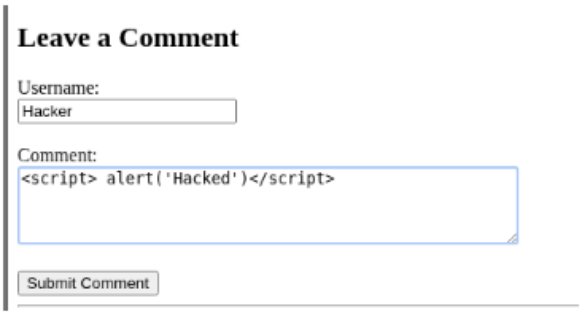
Objective

Inject malicious JavaScript into the Comments page that executes in every victim's browser when the page is loaded.

Vulnerable Page



Payload Used



Steps

- Open Firefox in Kali Linux and navigate to http://192.168.30.113/Comments.aspx
- A 'Leave a Comment' form appears with Username and Comment fields
- Enter Username: Hacker
- Enter the XSS payload in the Comment field
- Click Submit Comment

Verification on Victim Machine

Open Firefox on the Windows Server 2019 victim machine and browse to http://192.168.30.113/Comments.aspx. When the page loads, a JavaScript alert box fires with the injected message — confirming stored XSS execution.

Why It Works

- The application stores the comment in the database without sanitization
- When the page is rendered, the stored script tag is reflected in the HTML without HTML encoding
- The browser treats the injected content as executable JavaScript

Impact

- Session hijacking — attacker can steal authentication cookies
- Credential theft — fake login overlays can be injected
- Phishing injection — page content can be completely replaced
- Admin account takeover — if an admin views the page

Phase 4 — Brute Force Attack (Hydra)

Objective

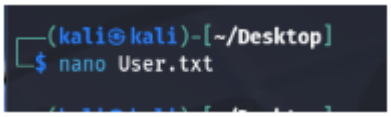
Discover valid usernames and passwords for the web application without prior knowledge.

Step 1 — Username Enumeration

The application returns different error messages for invalid usernames vs. invalid passwords:

- "User does not exist" — username is not in the database
- "Invalid password" — username exists but password is wrong

This difference allows Hydra to enumerate valid usernames. Create a wordlist:



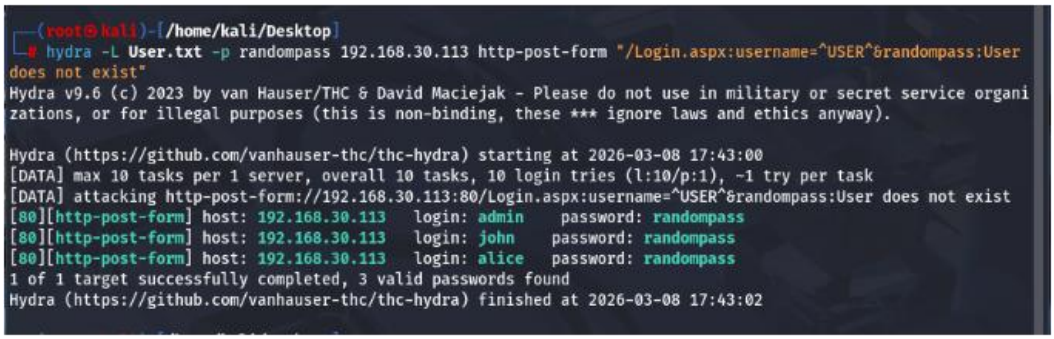
Contents of User.txt (usernames to test):



Switch to root and stay in Desktop directory:



Run Hydra username enumeration:



Discovered valid usernames from output:

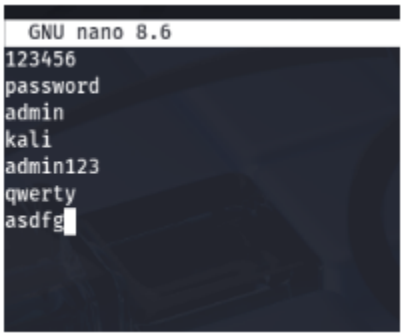
- admin
- alice
- john

Step 2 — Password Brute Force

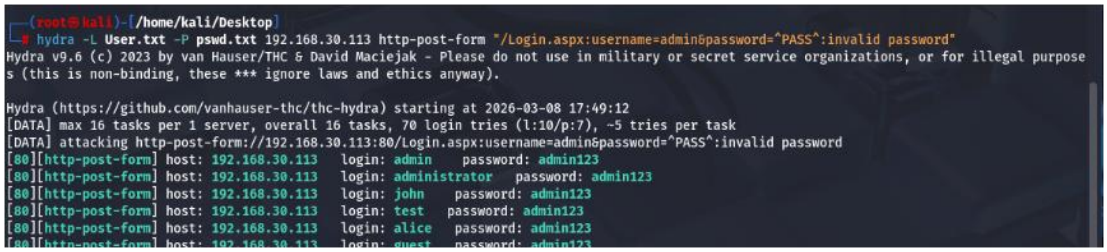
Create a password wordlist:



Contents of pswd.txt:



Run Hydra password brute force for each discovered username. Example using all usernames:



Results

Username	Password	Status
admin	admin123	Valid — Login Successful
administrator	admin123	Valid — Login Successful
john	admin123	Valid — Login Successful
alice	admin123	Valid — Login Successful
test	admin123	Valid — Login Successful

8. Attack Chain Summary

Phase	Vulnerability	Impact
1 — Nmap Scan	Open port discovery	Attack surface identified; target OS revealed
2 — SQL Injection	Input validation failure	Authentication bypassed without valid credentials
3 — Stored XSS	No output encoding	Malicious JS executes in victim/admin browsers
4 — Brute Force	No lockout / weak passwords	Full credential set discovered — account takeover

Full Compromise Path

- Attacker scans network → identifies Windows target on LAN via pfSense
- Discovers web service running on port 80 (HTTP)
- Exploits SQL Injection → bypasses login page without credentials
- Injects stored XSS → compromises any user who visits the Comments page
- Performs brute force with Hydra → obtains valid credentials for multiple accounts
- Achieves persistent authenticated access to the web application

9. Conclusion

This lab successfully demonstrates how multiple low-level vulnerabilities can chain together into a full system compromise. The pfSense firewall correctly segments the network, placing the victim on a protected LAN. However, firewall-level protection alone is insufficient — the web application itself contains critical flaws that allow an external attacker to breach it.

Key takeaways from the lab:

- Network segmentation using pfSense provides a strong first line of defense, but does not protect against application-layer attacks.
- SQL Injection vulnerabilities arise from unsanitized database queries and must be mitigated using parameterized queries or prepared statements.
- Stored XSS attacks persist in the database and affect every user who loads the page. All user-supplied input must be HTML-encoded before rendering.
- Brute-force attacks succeed when no account lockout is enforced and weak passwords are used. Rate limiting, CAPTCHA, and strong password policies are essential.

Poor input validation combined with weak authentication controls equals catastrophic exposure — even behind a properly configured firewall.